

TP1 - Initiation à l'OSINT

Introduction

L'OSINT (Open Source Intelligence) désigne l'ensemble des techniques permettant de collecter, analyser et exploiter des informations accessibles publiquement. Dans ce TP, vous allez découvrir trois techniques fondamentales utilisées par les professionnels de la cybersécurité et du renseignement :

1. Les Google Dorks : requêtes avancées pour cibler précisément des informations sur le web
2. Le WHOIS : recherche d'informations sur les propriétaires de domaines
3. L'analyse de métadonnées : extraction d'informations cachées dans les fichiers

Ces techniques sont légales lorsqu'elles sont utilisées de manière éthique pour la recherche d'informations publiques.

Partie 1 : Requêtes avancées Google (Google Dorks)

1.1 Qu'est-ce que le Google Dorking ?

Le Google Dorking (ou Google Hacking) est une technique de recherche avancée créée en 2002 par Johnny Long, expert en cybersécurité. Elle utilise des opérateurs spécifiques pour affiner les résultats de recherche et révéler des informations souvent invisibles via une recherche classique.

1.2 Principaux opérateurs Google Dorks

Voici les opérateurs essentiels à maîtriser pour ce TP :

Opérateur	Description	Exemple
site:	Limite la recherche à un domaine spécifique	site:.gouv.fr
filetype:	Recherche un type de fichier précis	filetype:pdf
inurl:	Recherche un terme dans l'URL	inurl:admin
intitle:	Recherche un terme dans le titre de la page	intitle:"index of"
"expression"	Recherche une expression exacte	"budget 2024"
- (moins)	Exclut un terme des résultats	cybersécurité -cours
OR	Recherche l'un ou l'autre terme	OSINT OR "Open-Source Intelligence"
after: / before:	Filtre par date	after:2023-01-01

1.3 Exemples de requêtes pour le TP

Voici des exemples de requêtes à tester dans le cadre de ce TP :

Objectif	Requête Google Dork	Résultat attendu
Documents budgétaires gouvernementaux	filetype:pdf site:.gouv.fr "budget 2024"	PDF gouvernementaux contenant "budget 2024"
Rapports publics ministériels	site:education.gouv.fr filetype:pdf rapport	Rapports PDF du ministère de l'Education
Documents Excel gouvernementaux	filetype:xls site:.gouv.fr	Tableaux Excel sur sites gouvernementaux
Rapports annuels d'entreprises	filetype:pdf site:.fr "rapport annuel" 2024	Rapports annuels d'entreprises françaises
Documents sur période précise	filetype:pdf site:.gouv.fr after:2023-01-01	Documents publiés en 2023-2024

1.4 Consignes pour l'étape 1

1. Testez au minimum 3 requêtes Google Dorks différentes en variant les opérateurs
2. Pour chaque requête : Faites une capture d'écran montrant la requête et les résultats, Sélectionnez 1 ou 2 résultats pertinents, Ouvrez-le document/la page et faites une nouvelle capture
3. Analysez et interprétez : Quel type d'information avez-vous trouvé ? Quelle est la pertinence en contexte OSINT ? Quels risques de sécurité cela révèle-t-il ?

IMPORTANT : Restez dans un cadre légal et éthique. Ne téléchargez pas de documents marqués "confidentiel" et n'accédez pas à des interfaces d'administration.

Partie 2 : Recherche WHOIS sur un domaine

2.1 Qu'est-ce que WHOIS ?

WHOIS est un protocole de requête permettant d'interroger des bases de données publiques pour obtenir des informations sur les propriétaires de noms de domaine. Il fonctionne comme un "annuaire d'Internet".

2.2 Informations disponibles dans un enregistrement WHOIS

Un enregistrement WHOIS typique contient les informations suivantes :

Champ WHOIS	Information révélée	Intérêt OSINT
Nom de domaine	Le domaine exact interrogé	Vérification de la cible
Registrar	Entreprise gérant l'enregistrement (ex : OVH, GoDaddy)	Identifier l'hébergeur
Date de création	Quand le domaine a été enregistré	Estimer l'ancienneté et la crédibilité
Date d'expiration	Date à laquelle le domaine expire	Savoir si proche d'expiration
Nameservers	Serveurs DNS hébergeant le domaine	Identifier l'infrastructure
Statut du domaine	Etat (actif, verrouillé, en attente)	Détecter des anomalies
Contact registrant	Propriétaire (si non masque)	Identifier le propriétaire réel
Contact administratif	Personne gérant le domaine	Point de contact
Contact technique	Responsable technique	Contact pour problèmes techniques

Note : Depuis l'entrée en vigueur du RGPD, de nombreux contacts sont masqués par des services de confidentialité WHOIS.

2.3 Outils WHOIS recommandés

Vous pouvez utiliser l'un de ces outils gratuits :

En ligne :

- <https://whois.domaintools.com>
- <https://who.is>
- <https://www.whois.com>
- <https://www.afnic.fr/outils/whois/> (pour les domaines .fr)

Ligne de commande (Linux/MacOs) :

- `whois exemple.fr`

2.4 Consignes pour l'étape 2

1. Choisissez un domaine à analyser (par exemple, un site trouvé lors de l'étape 1, ou un site public comme education.gouv.fr)
2. Effectuez une recherche WHOIS avec l'un des outils recommandés
3. Capturez l'écran des résultats WHOIS complets
4. Analysez les informations : Identifiez le registrar, Notez les dates (création, expiration), Identifiez les Name servers, Vérifiez le statut du domaine, Notez si les contacts sont masqués ou publics
5. Interprétez : Que révèlent ces informations sur l'organisation ? Le domaine est-il récent ou ancien ? Les informations de contact sont-elles protégées ?

Partie 3 : Analyse des métadonnées accessibles

3.1 Qu'est-ce que les métadonnées ?

Les métadonnées sont des "données sur les données". Dans un fichier PDF, Word ou image, elles contiennent des informations sur l'auteur, la date de création, le logiciel utilisé, et bien d'autres détails souvent invisibles à l'œil nu.

3.2 Métadonnées communes dans les fichiers PDF

Voici les métadonnées typiques que vous pouvez extraire d'un document PDF :

Type de métadonnée	Ce qu'elle révèle	Risque/Intérêt OSINT
Titre	Titre officiel du document	Peut révéler des infos confidentielles
Auteur	Nom de la personne ayant créé le document	Identifier l'employé/service
Sujet	Description du contenu	Contexte du document
Date de création	Quand le document a été créé	Datation précise
Date de modification	Dernière modification	Savoir si récemment modifié
Application créatrice	Logiciel utilisé (Word, InDesign, etc.)	Révèle les outils internes
Producteur PDF	Logiciel de conversion en PDF	Workflow de production
Version PDF	Version du standard PDF	Compatibilité
Nombre de pages	Total de pages	Taille du document

ATTENTION : Les métadonnées peuvent être facilement modifiées ou supprimées. Il faut donc toujours vérifier leur cohérence avec d'autres sources.

3.3 Outils d'analyse de métadonnées

Plusieurs outils gratuits permettent d'extraire les métadonnées :

Outils en ligne :

- <https://www.metadata2go.com> (multiformats)
- <https://www.get-metadata.com> (images et documents)
- <https://exif.tools> (EXIF pour images)
- <https://pics.io/pdf-metadata-viewer> (spécialise PDF)

Outils à télécharger :

- ExifTool (<https://exiftool.org>) - Très puissant, ligne de commande
- Adobe Acrobat Reader - Propriétés du document (Fichier > Propriétés)

Ligne de commande (Linux/MacOs) :

- `exiftool document.pdf`
- `pdftk document.pdf`

3.4 Consignes pour l'étape 3

1. Téléchargez un document public (par exemple, un PDF trouvé à l'étape 1 via Google Dorks)
2. Analysez ses métadonnées avec l'un des outils recommandés
3. Capturez l'écran de l'analyse des métadonnées
4. Identifiez les informations suivantes : Auteur du document, Date de création et de modification, Logiciel utilisé pour créer le document, Logiciel utilisé pour la conversion en PDF, Version du PDF
5. Interprétez : Que révèlent ces métadonnées sur l'origine du document ? Y a-t-il des incohérences ? Quelles informations pourraient être sensibles d'un point de vue sécurité ? Quels outils l'organisation utilise-t-elle en interne ?

Conseils pour la réalisation

Pour les captures d'écran

- Assurez-vous que les captures sont lisibles et de bonne qualité
- Incluez le contexte : la barre d'URL pour les pages web, le nom de l'outil utilisé
- Annotez vos captures si nécessaire (encadrer les éléments importants)
- Numérotez vos captures et référez-les dans le texte

Pour l'interprétation

- Ne vous contentez pas de décrire, analysez !
- Posez-vous les questions : Qu'est-ce que cette information révèle ? Quel est le risque pour l'organisation ? Comment cette information pourrait-elle être exploitée ? Quelles recommandations de sécurité formuler ?

Aspects éthiques et légaux

- Restez dans la légalité : n'accédez qu'à des informations publiques
- Ne téléchargez pas de documents marqués "confidentiel" ou "interne"
- N'essayez pas d'accéder à des interfaces d'administration
- Utilisez ces techniques de manière responsable et éthique

Grille d'évaluation

Critère	Points	Détails
Qualité des requêtes Google Dorks	/5	Pertinence des opérateurs, diversité des requêtes
Analyse WHOIS	/5	Identification correcte des champs, interprétation
Extraction de métadonnées	/5	Outil utilisé, métadonnées extraites
Interprétation et analyse critique	/3	Analyse de sécurité, risques identifiés, recommandations
Présentation et structure	/1	Clarté, orthographe, organisation
Respect des consignes	/1	Toutes les étapes réalisées
TOTAL	/20	

Ressources complémentaires

Documentation Google Dorks

Google Hacking Database (GHDB) : <https://www.exploit-db.com/google-hacking-database>

Rappel

L'OSINT est un outil puissant qui doit être utilisé de manière éthique et responsable. La frontière entre recherche légitime et intrusion malveillante réside dans vos intentions et le respect de la légalité.

Bon travail !
